Threats to Information Resources & Cyber Law

IUT – Legal Issues and Cyber Law

Aashnan Rahman
Junior Lecturer, IUT CSE

Winter 2024–25

Outline

1. Introduction to Information Security Threats
2. Military & Economic Espionage
3. Communications Eavesdropping
4. Computer Break-ins & Denial-of-Service
5. Data Destruction, Modification & Fabrication
6. Cyber Privacy
7. Cyber Defamation & Conflicts
8. Computer Crime & Information Terrorism
9. Conclusion

Why Information Resources Are Under Threat

! Information is the **most valuable asset** of the 21st century

→ Digital transformation expanded the **attack surface** exponentially

Motivations:

- Financial gain
- Political / military advantage
- Ideological causes
- Personal grudges

Key Statistic

Global cybercrime costs projected to reach **$10.5 trillion annually** by 2025

— Cybersecurity Ventures

Threat Actors:

1. Nation-states
2. Hacktivists
3. Organized crime
4. Insiders
5. Lone wolves

Taxonomy of Threats to Information Resources

Passive Threats

- Eavesdropping
- Traffic analysis
- Espionage
- Surveillance

Active Threats

- Data modification / destruction
- Denial-of-Service (DoS)
- Computer break-ins
- Forgery & fabrication
- Information warfare

Key Insight: Modern attacks often **combine passive and active** techniques — e.g., reconnaissance (passive) followed by exploitation (active)

Military Espionage in the Cyber Age

- Nation-states deploy **Advanced Persistent Threats (APTs)** to steal classified data
- **Targets:**
  - Defense contractors
  - Military networks
  - Intelligence agencies
- **Techniques:**
  - Spear-phishing
  - Zero-day exploits
  - Supply-chain attacks

Case: SolarWinds Attack (2020)

- **Who:** Russian-linked APT29 (“Cozy Bear”)
- **How:** Compromised SolarWinds Orion software updates
- **Impact:** **18,000+ organizations** infiltrated (U.S. DoD, Treasury, DHS)
- **Significance:** Most sophisticated espionage operation ever discovered

Economic & Industrial Espionage

- Theft of **trade secrets, patents, R&D data** for competitive advantage
- State-sponsored actors target:
  - Technology sector
  - Pharmaceutical industry
  - Energy companies
- **Legal Framework:** U.S. Economic Espionage Act of 1996

Case: Chinese APT10 / Cloud Hopper (2018–2019)

- **Who:** APT10 (Chinese state-sponsored)
- **Target:** Managed IT service providers in **12+ countries**
- **Stolen:** Hundreds of GBs from NASA, U.S. Navy, major corporations
- **Outcome:** Two Chinese nationals indicted by U.S. DOJ

Pegasus Spyware (NSO Group)

What is Pegasus?

- Military-grade spyware by Israeli firm NSO Group
- Sold to governments worldwide
- **Zero-click exploit:** No user interaction needed
- Exploited iMessage, WhatsApp vulnerabilities

2021 Pegasus Project Revelations

- **50,000+** phone numbers targeted
- Victims: journalists, activists, heads of state
- Targets included French President Macron
- U.S. blacklisted NSO Group (Nov 2021)

Key Debate **Surveillance vs. Human Rights** — Should governments be allowed to purchase and deploy commercial spyware against their own citizens?

Communications Eavesdropping

Types of Eavesdropping

- Wiretapping — telephony interception
- Packet sniffing — network traffic capture
- MitM attacks — intercepting communications
- IMSI catchers / Stingrays — mobile interception

Legal Frameworks

- U.S. Wiretap Act
- EU e-Privacy Directive
- Electronic Communications Privacy Act (ECPA)
- Regulation of Investigatory Powers Act (UK)

Case: Edward Snowden Revelations (2013)

- **PRISM:** Collected data from Google, Facebook, Apple, and others
- **XKeyscore:** Searched virtually all internet activity in real-time
- **Impact:** Triggered worldwide privacy reform & USA FREEDOM Act (2015)

Recent Eavesdropping Cases

Case: Salt Typhoon – Telecom Hack (2024)

- **Who:** Chinese state-sponsored group "Salt Typhoon"
- **Targets:** AT&T, Verizon, T-Mobile
- **Accessed:** Call metadata & **law enforcement wiretap systems**
- **Quote:** FBI Director Wray called it the *"most significant cyber espionage campaign in history"* targeting U.S. telecoms

Case: Greek Wiretapping Scandal (2004–2005)

- **What:** Rogue software implanted in Vodafone Greece's network
- **Targets:** **Prime Minister** and 100+ senior officials
- **When:** During the Athens Olympics period
- **Who:** Perpetrators remain **unidentified** to this day

Computer Break-ins (Unauthorized Access)

Common Methods

- Brute force attacks
- Credential stuffing
- SQL injection
- Privilege escalation
- Social engineering

Relevant Legislation

- Computer Fraud & Abuse Act (CFAA, U.S.)
- Computer Misuse Act (UK)
- IT Act 2006 (Bangladesh)
- Convention on Cybercrime (Budapest)

Case: Colonial Pipeline Ransomware (2021)

- **Who:** DarkSide ransomware group
- **Entry Point:** Single **compromised VPN password**
- **Impact:** Largest U.S. fuel pipeline shut down for **6 days**
- **Ransom:** $4.4 million paid → Led to U.S. executive order on cybersecurity

Denial-of-Service (DoS) & DDoS Attacks

What is DDoS?

- **Goal:** Overwhelm a service with traffic
- Uses **botnets** (millions of compromised devices)
- DDoS-for-hire (“booters”) lowered barrier to entry

Attack Types

1. **Volumetric** — flood bandwidth
2. **Protocol** — exploit TCP/IP weaknesses
3. **Application-layer** — target HTTP/DNS services

Case: Mirai Botnet (2016)

- **Method:** Exploited IoT devices (cameras, routers) to build massive botnet
- **Target:** Dyn DNS provider
- **Victims:** Twitter, Netflix, Reddit, Spotify taken offline
- **Scale:** Peak traffic of **1.2 Tbps**

Recent DDoS Attacks

Case: Google Cloud – Record-Breaking DDoS (2023)

- **Scale: 398 million requests/second** — largest ever recorded
- **Comparison:** 7.5× larger than previous record
- **Exploit:** HTTP/2 "Rapid Reset" zero-day (CVE-2023-44487)
- **Outcome:** Successfully mitigated by Google's infrastructure

Case: Russia–Ukraine Cyber War (2022–Present)

- **Russian side:** Massive DDoS on Ukrainian government, banks, infrastructure
- **Timing:** Attacks preceded and accompanied the physical invasion
- **Ukrainian response:** Volunteer "IT Army" retaliated against Russian targets
- **Significance:** First large-scale **hybrid warfare** combining cyber & kinetic attacks

Destruction & Modification of Data

Destruction

- Wiping storage media
- Encrypting data (ransomware)
- Physical damage to hardware
- Wiper malware

Modification

- Altering database records
- Changing system configurations
- Tampering with logs
- Manipulating financial data

Motivations: Sabotage • Extortion • Covering tracks • Geopolitical

Case: NotPetya (2017)

- **Disguise:** Looked like ransomware but was actually a **wiper** (irreversible)
- **Vector:** Ukrainian tax software (M.E.Doc) update
- **Damages: \$10+ billion** globally (Maersk, Merck, FedEx)
- **Attribution:** Russian military intelligence (GRU)

Distortion & Fabrication of Information

Distortion

- Manipulation of **genuine** information to mislead
- Altered images / videos
- Quotes taken out of context
- Misleading statistics

Fabrication

- AI-generated text & images
- Deepfake videos
- Forged documents
- Fake news articles

Threatens: Elections • Markets • Public health • National security

Case: Deepfake CFO Scam, Hong Kong (2024)

- **Method:** Real-time **deepfake video** of CFO & colleagues on a video call
- **Victim:** Employee convinced to transfer **$25 million**
- **Key Detail:** Multi-person video conference — all participants were deepfakes
- **Lesson:** Visual verification alone is **no longer reliable**

Forgery in the Digital Age

Types of Digital Forgery

- Fake certificates & diplomas
- Forged emails (spoofing)
- Spoofed identities
- Counterfeit documents
- Business Email Compromise (BEC)

BEC Impact FBI reports BEC caused **$2.7 billion** in losses in 2022 alone

Forged emails from "executives" authorize fraudulent wire transfers

Case: Bangladesh Bank Heist (2016)

- **Who:** Lazarus Group (North Korea)
- **Method:** Forged **SWIFT banking messages**
- **Attempted:** $951 million from Bangladesh Bank's NY Fed account
- **Stolen:** **$81 million** successfully transferred
- **Caught by:** A **typo** — "fandation" instead of "foundation"

Cyber Privacy – Key Concepts

Privacy Rights Online

- Control over personal data collection
- Right to consent before data use
- Right to be forgotten
- Transparency in data processing

Key Concerns

- Mass surveillance by governments
- Data harvesting by corporations
- Data breaches exposing PII
- Location tracking & profiling

Major Privacy Legislation

GDPR	**CCPA**	**POPIA**	**DSA**
EU (2018)	California (2020)	South Africa (2021)	Bangladesh (2018)

Cyber Privacy – Landmark Cases

Case: Facebook–Cambridge Analytica (2018)

- **What:** Data of **87 million** users harvested **without consent**
- **Used for:** Political advertising (2016 U.S. election & Brexit)
- **Fine:** Facebook fined **$5 billion** by FTC
- **Significance:** Largest privacy fine at the time; sparked global privacy reform

Case: 23andMe Data Breach (2023)

- **Method:** Credential stuffing attack
- **Exposed:** Genetic data of **6.9 million users**
- **Sold on:** Dark web forums
- **Key Question:** How should **genetic data privacy** be regulated?

Cyber Defamation

Definition & Platforms

- Publishing **false & damaging** statements online
- Social media platforms
- Blogs & forums
- Review sites
- Messaging apps

Key Challenges

- Anonymity of posters
- Viral spread — *"the internet never forgets"*
- Cross-border jurisdiction issues
- Platform liability questions

Legal Remedies

Takedown Orders	**Damages**	**Criminal Prosecution**
Court-ordered removal	Monetary compensation	Varies by jurisdiction

Information Warfare – Concepts

Offensive Operations

- Cyberattacks on infrastructure
- Propaganda campaigns
- Psychological operations (PsyOps)
- Malware deployment

Defensive Operations

- Protecting own systems
- Threat intelligence
- Counter-narrative strategies
- Public awareness campaigns

Information warfare is the **“Fifth Domain”** of warfare (alongside land, sea, air, space)

It blurs the line between war and peace — attacks often occur **below the threshold of armed conflict**

Information Warfare – Notable Campaigns

Case: Russian Interference in U.S. Elections (2016)

- **Social media:** Internet Research Agency (IRA) ran massive **disinformation campaigns**
- **Hacking:** GRU breached DNC servers; emails leaked via WikiLeaks
- **Goal:** Combine cyber operations with PsyOps to **influence public opinion**
- **Reach:** IRA content reached **126 million** Americans on Facebook alone

Case: Stuxnet – The First Cyber Weapon (2010)

- **Who:** U.S.–Israeli joint operation ("Olympic Games")
- **Target:** Iranian nuclear centrifuges at Natanz facility
- **Result:** Destroyed **1,000 centrifuges** via malware
- **Significance:** First known cyberattack causing **physical destruction**
- **Legacy:** Ushered in the era of state-sponsored cyber warfare

Computer Crime – Categories

Crimes Against Individuals

- Identity theft
- Phishing / social engineering
- Cyberstalking
- Sextortion
- Online fraud

Crimes Against Organizations / States

- Ransomware attacks
- Corporate espionage
- Critical infrastructure attacks
- Money laundering (crypto)
- Intellectual property theft

Scale of the Problem (FBI IC3 Report, 2023)

880,418	**$12.5 billion**	**+22%**
Complaints received	Total losses	Increase from 2022

Information Terrorism – Cyber Terrorism

Definition

Use of cyber capabilities to cause **fear, disruption, or harm** in furtherance of ideological goals

Primary Targets

- Power grids
- Water systems
- Hospitals
- Transportation
- Government systems

Terrorist Use of Internet

- Recruitment & radicalization
- Propaganda dissemination
- Encrypted communications
- Fundraising via cryptocurrency
- Training manuals

Irish Health Service (HSE) Attack (2021)

Case: Irish Health Service (HSE) Attack (2021)

- **Who:** Conti ransomware group
- **Target:** Ireland's **entire public healthcare system**
- **Impact:** Hospitals on paper records; surgeries & cancer treatments cancelled
- **Cost: €100+ million** recovery → **Cyberattacks can endanger lives**

Recent High-Profile Cybercrime Cases

Case: MOVEit Supply-Chain Attack (2023)

- **Who:** Cl0p ransomware gang
- **Method:** Zero-day exploit in MOVEit file transfer software
- **Scale: 2,600+ organizations** and **77 million individuals** affected
- **Victims:** BBC, British Airways, U.S. Department of Energy
- **Lesson:** Supply-chain vulnerabilities have **cascading effects**

Case: MGM Resorts & Caesars Entertainment (2023)

- **Who:** Scattered Spider (ALPHV/BlackCat affiliate)
- **Method:** Social engineering — a **10-minute phone call** to IT help desk
- **MGM Loss: $100+ million**; casino ops, hotel check-ins, ATMs disrupted
- **Caesars:** Paid **$15 million** ransom
- **Lesson:** Humans remain the **weakest link** in security

Key Takeaways & the Road Ahead

1. Threats are **growing in sophistication and scale**
2. Lines between **cybercrime, espionage, and warfare** are blurred
3. **AI & deepfakes** create new threat categories
4. **Legal frameworks** must evolve with international cooperation
5. **Privacy vs. Security** remains the central tension
6. **Cyber hygiene** is everyone's responsibility

Discussion Question Should nations agree on a **"Geneva Convention for Cyberspace"**?

- What would it cover?
- How would it be enforced?
- Who would be the signatories?

"The only truly secure system is one that is powered off, cast in a block of concrete and sealed in a lead-lined room with armed guards."

— Gene Spafford